

Warsaw, January 17, 2024

Decision

ZSPR.421.2.2019 ZSPR.405.67.2019

Warsaw, January 17, 2024

ZSPR.421.2.2019

ZSPR.405.67.2019

## DECISION

Based on Article 104 § 1 and Article 105 § 1 of the Act of June 14, 1960, the Code of Administrative Procedure (Journal of Laws of 2023, item 775, as amended) and Article 7 § 1 and § 2, Article 60, Article 90, Article 101, and Article 103 of the Personal Data Protection Act of May 10, 2018 (Journal of Laws of 2019, item 1781) as well as Article 57 § 1 lit. a) and lit. h), Article 58 § 2 lit. i), Article 83 § 1 – 3, Article 83 § 4 lit. a) in connection with Article 24 § 1, Article 25 § 1 and Article 32 § 1 lit. b) and d) and § 2, and also Article 83 § 5 lit. a) in connection with Article 5 § 1 lit. a) and lit. f), Article 5 § 2, Article 6 § 1, Article 7 § 1 of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of 04.05.2016, p. 1, as amended), after conducting an ex officio administrative proceeding regarding the violation of personal data protection regulations by Morele.net sp. z o.o. based in Krakow at al. Jana Pawła II 43b, the President of the Personal Data Protection Office,

I. finding that Morele.net sp. z o.o. based in Krakow violated the provisions of Article 24 § 1, Article 25 § 1, Article 32 § 1 lit. b) and lit. d) as well as Article 32 § 2 of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of 04.05.2016, p. 1, as amended), hereinafter referred to as "Regulation 2016/679", consisting of:

a) failure to implement appropriate technical and organizational measures to ensure the security of data processing in information systems and to protect the rights of data subjects, based on a risk analysis taking into account the state of technical knowledge, the cost of implementation, the nature, scope, context, and purposes of processing, and the risk of infringement of the rights or freedoms of natural persons,

b) failure to implement appropriate technical and organizational measures to ensure regular testing, measuring, and evaluating the effectiveness of technical and organizational measures intended to ensure the security of personal data processed in information systems, particularly regarding vulnerabilities, errors, and their possible consequences for these systems and the actions taken to minimize the risk of their occurrence,

resulting in a violation of the principle of integrity and confidentiality (Article 5 § 1 lit. f) of Regulation 2016/679) and the principle of accountability (Article 5 § 2 of Regulation 2016/679), imposes on Morele.net sp. z o.o. based in Krakow for the violation of Article 5 § 1 lit. f), Article 5 § 2, Article 25 § 1 and Article 32 § 1 lit. b) and lit. d) and § 2 of Regulation 2016/679 an administrative fine in the amount of 3,819,960 PLN (in words: three million eight hundred nineteen thousand nine hundred sixty PLN).

II. in the remaining scope, terminates the proceedings.

## JUSTIFICATION

On November 30, 2018, Morele.net Sp. z o.o. based in Krakow at ul. Fabryczna 20A, currently at al. Jana Pawła II 43b (hereinafter referred to as the "Company" or "Morele.net"), reported to the President of the Personal Data Protection Office (hereinafter also referred to as the "President of UODO" or "Supervisory Authority") two breaches of personal data protection, which involved unauthorized access by an unauthorized person to the database of customers of the online stores morele.net, (...), (...), (...), (...), (...), (...), (...) and unauthorized access by an unauthorized person to an employee's account of the Company, consequently obtaining personal data of customers making purchases in the

aforementioned online stores. Subsequently, on December 16, 2018, the Company reported to the President of the Personal Data Protection Office another breach of personal data protection involving unauthorized access to an employee's account of the Company.

From January 21 to 25, 2019, in order to verify compliance of data processing with personal data protection regulations, control activities were conducted at Morele.net. The scope of the control covered the processing of personal data of customers of the online stores: morele.net, (...), (...), (...), (...), (...), (...), (...), (...) for which the Company is the administrator.

Based on the collected evidence, it was established that in the process of personal data processing, the Company, as the administrator, violated the provisions of personal data protection regulations. These deficiencies consisted of:

The Company's violation of the principle of integrity and confidentiality of data expressed in Article 5 § 1 lit. f)

Regulation 2016/679, reflected in the form of obligations specified in Article 24(1), Article 25(1), Article 32(1)(b) and (d), and Article 32(2) of Regulation 2016/679, concerning the failure to ensure the security and confidentiality of processed personal data, which resulted in unauthorized individuals gaining access to the personal data of the Company's clients.

Violation of the principle of lawfulness, fairness, and transparency, as well as the principle of accountability, expressed in Article 5(1)(a) and Article 5(2) of Regulation 2016/679, detailed in Article 7(1) and Article 6(1) of Regulation 2016/679, through the failure to demonstrate that the personal data from installment applications collected before May 25, 2018, were processed by Morele.net based on the consent of the data subject.

The President of the Personal Data Protection Office (UODO), based on the collected evidence, established the following factual state of the case:

1. The subject of the Company's activity is retail sales conducted through mail order houses or the Internet. The Company operates online stores: morele.net, (...), (...), (...), (...), (...), (...), (...), (...), (...).

2. In connection with its business activities, the Company processes personal data of clients who registered on the morele.net website (and on the websites of other stores mentioned above, for which the Company is the administrator). The number of individuals whose data is processed by the Company is approximately 2,200,000 (about two million two hundred thousand). The scope of this data includes: first name, last name, email address, phone number, and delivery address, and access to this data is held by (...). Until December 2018, the Company also processed data from installment applications. The scope of this data included: first name, last name, email address, phone number, PESEL number, series and number of identity document, date of issue of the identity document, date of validity of the identity document, education, registered address, correspondence address, source of income, monthly net income, household maintenance costs, number of dependents, marital status, amount of monthly other obligations in financial institutions, information on the amount of alimony obligations and other obligations arising from court judgments (collected since 2016). Their total number was approximately 35,000. (...)

3. On (...) November 2018, the Company was informed by clients about receiving short text messages (SMS) informing them of the need to make an additional payment of 1 PLN to complete the order. The message contained a link to a fraudulent electronic payment gateway DotPay. The Company immediately notified the Police about the incident and began efforts to clarify the matter. (...)

4. The breach of personal data protection was identified by the Company on (...) November 2018.

5. After conducting monitoring activities, on November 30, 2018, the Company reported the breach to the President of the Personal Data Protection Office. Furthermore, the Company posted a warning about fraudulent SMS messages on its website. The same information was sent by the Company to clients in email and SMS messages. On (...) December 2018, the Company again informed the data subjects about the breach, including information about the potential access to data from installment applications.

6. As indicated in the reports sent to the President of the Personal Data Protection Office and supplementary reports, the Company undertook work on implementing additional technical security measures, including two-step authentication for access to the employee panel. (...)
7. On (...) November 2018, the Company received an email from an unknown person informing about the theft of the Company's customer database.
8. On November 30, 2018, the Company reported to the President of UODO a breach of personal data protection concerning the potential unauthorized access to the Company's customer database. The breach involved approximately 2,200,000 (about two million two hundred thousand) users.
9. On (...) December 2018, the Company sent approximately 2,200,000 (about two million two hundred thousand) email notifications to clients regarding unauthorized access to the customer database (the content of the notification to the data subjects was sent in the supplementary report of the personal data breach).
10. In the above information directed to the Company's clients, the Company informed that it does not process data from credit applications.
11. On (...) December 2018, the Company identified another unauthorized access (...), used for the resending of fraudulent SMS messages, of which 600 individuals, whose data the unauthorized person had access to, were informed. Following this incident, on the same day, the Company implemented two-factor authentication, which it had been working on since November 30, 2018. On December 16, 2018, this breach was reported to the President of the Personal Data Protection Office.
12. In order to determine the circumstances of the data protection breaches reported by the Company and to ascertain the technical security measures applied by the Company, measures taken to minimize the effects of the breach, and to prevent similar incidents, on January 7, 2019, the President of UODO issued a request to the Company for explanations.  
In response to the request dated January 7, 2019, the Company, in a letter dated January 17, 2019, provided extensive explanations, including, among others: a description of the actions taken by the Company following the incident, a description of the technical and organizational security measures employed by the Company, and a description of the procedure for handling requests from individuals whose data is concerned. The explanations dated January 17, 2019, were accompanied by the financial report for the financial year from (...).01.2017 to (...).12.2017, which indicates that the amount of net revenue from sales and equivalent sources is: 718,610,021.32 PLN, as well as a statement from the Management Board regarding the total revenue of the Company for the year 2018, calculated as of (...) January 2019, which amounts to 795,860,906.08 PLN.

As established during the inspection, making purchases in online stores administered by the Company requires prior registration. The necessary information to create an account includes an email address and a password for the user account, which is entered by the store customer. After logging in, the user has the option to enter their first name, last name, address, and phone number (for the purpose of establishing basic data necessary for the delivery of purchased goods). The user account exists in the Company's system until the contract is terminated, i.e., until the account is deleted by the user.

As established during the inspection, in 2016, the documentation regarding the processing of personal data applicable in the Company was updated. In 2017, the Company began work related to the upcoming date for the implementation of the provisions of Regulation 2016/679, concerning the adaptation of the website, user profile, newsletter, adaptation of internal documents within the Company, document circulation within the Company, and physical and technical security measures. As indicated in the explanations accepted during the inspection, the risk analysis was conducted by the Company on an ad hoc basis for individual processes in an informal manner.

During the inspection, a copy of the Company's internal documentation titled "Report after the Data Breach" was obtained.

As established during the inspection, the module handling the credit application form does not save in

the Company's database the information entered by the Customer. According to the explanations accepted during the inspection, the Company did not collect data regarding scans of identity documents belonging to customers submitting credit applications. The installment purchase form from approximately (...) October 2018 included a space to enter only the amount of alimony obligations or the amount of obligations resulting from other court rulings. The Company does not confirm that such data was recorded in the database deleted in December 2018.

In a letter dated February 19, 2019, the Company requested the President of the Personal Data Protection Office to urgently consider the matter, indicating that due to the media nature of the case and uncertainty regarding how the matter would be concluded by the President of the Personal Data Protection Office, any prolonged consideration of the case could pose a threat to the functioning of the Company.

The President of the Personal Data Protection Office, in a decision dated August 6, 2019, refused to grant the Company's request for an expert opinion, indicating, among other things, that the assessment of whether the technical and organizational measures employed by the Company met the standards was not of significant importance for issuing a resolution in the matter, and the circumstance of whether the technical and organizational measures employed by the Company were appropriate, considering the state of technical knowledge, the cost of implementation, and the nature, scope, context, and purposes of processing, as well as the risk of infringement of the rights or freedoms of individuals with varying probabilities of occurrence and severity of threat, had already been sufficiently established based on the evidence obtained.

After analyzing the evidence collected in the administrative proceedings, the President of the Personal Data Protection Office, in a decision dated September 10, 2019, found that the Company violated the provisions of Article 5(1)(a) and (f), Article 5(2), Article 6(1), Article 7(1), Article 24(1), Article 25(1), Article 32(1)(b) and (d), and Article 32(2) of Regulation 2016/679.

Considering the established violation, the President of the Personal Data Protection Office concluded that in the circumstances of the case being resolved, the assessment of the conditions referred to in Article 83(2) of Regulation 2016/679 determined the necessity of imposing an administrative fine on the Company. The President of the Personal Data Protection Office, acting under Article 58(2)(i) of Regulation 2016/679 and Article 83(3) and Article 83(5)(a) of Regulation 2016/679 in connection with Article 103 of the Act of May 10, 2018, on the protection of personal data (Journal of Laws of 2019, item 1781), imposed an administrative fine on the Company in the amount of 2,830,410 PLN (which was equivalent to 660,000 EUR). The decision was delivered to the Company on September 16, 2019 (return receipt confirmation in the case files).

In a letter dated October 16, 2019 (date of receipt by the Personal Data Protection Office: October 18, 2019), the Company filed a complaint with the Provincial Administrative Court in Warsaw against the decision of the President of the Personal Data Protection Office dated September 10, 2019, challenging the issued decision in its entirety, demanding the annulment of the challenged decision and the awarding of costs of the proceedings. The complaint included both allegations of violations of procedural provisions and substantive law. It also contained a request for the Court to refer a question to the Court of Justice of the European Union for a preliminary ruling on whether administrative courts in Poland provide effective legal protection against a legally binding decision of a supervisory authority, i.e., whether they exercise full jurisdiction in establishing the factual circumstances.

**\*\*Legal Provisions Relevant to the Resolution of the Case\*\***

As mentioned in Article 78(1) of Regulation 2016/679 and in Recital (143) of the preamble to Regulation 2016/679, in a situation where the proceedings before the President of the Office are one-instance and there is no body or court that can assess the President's decision substantively or has the competence to make factual determinations, while Article 6 of the European Convention on Human Rights and Fundamental Freedoms and Article 47 of the Charter of Fundamental Rights guarantee the punished entity the right to have the case resolved by a court with full jurisdiction.

By judgment of September 3, 2020, case no. SA/Wa 2559/19, the Provincial Administrative Court in

Warsaw dismissed the complaint of Morele.net against the decision of the President of the Personal Data Protection Office (UODO) dated September 10, 2019. In the reasoning of the judgment, the first-instance court indicated, first of all, that it found no grounds to refer a preliminary question to the Court of Justice of the European Union (CJEU). Since decisions imposing sanctions are subject to appeal to the administrative court, it cannot be considered that the adopted rules violate the right to a court. To support this position, the Provincial Administrative Court cited the jurisprudence of the Constitutional Tribunal and indicated that financial penalties imposed by administrative bodies cannot be equated with fines or other institutions of criminal law, and the authority of the bodies in this regard cannot be perceived as administering justice.

Moving on to the assessment of the legality of the contested decision, the Provincial Administrative Court accepted that it contains a correctly formulated resolution. In the court's opinion, the operative part of the decision is understandable, and the legal grounds for the resolution arise from the justification. The court noted that in the notification of the initiation of proceedings, the authority indicated which violations identified during the inspection are the subject of the proceedings. Furthermore, the Provincial Administrative Court indicated that it shares the position of the President of UODO that the most serious violation, determining the imposed penalty, was the violation of the confidentiality principle expressed in Article 5(1)(f) in conjunction with Article 32(1)(b) and (d) in conjunction with Article 32(2) of Regulation 2016/679. The authority had grounds to assume that the cause of unauthorized access to the employee panel was an ineffective authentication measure, which was solely a login and password.

In the court's opinion, the complainant inadequately assessed the ability to continuously ensure confidentiality and did not take into account the risks associated with unauthorized access to the employee panel. Ineffective monitoring of potential threats to the rights and freedoms of individuals whose data were processed by the company contributed to unauthorized access to customer data from its database system. The court emphasized that the complainant—considering that it processes personal data of over 2,200,000 users—should have more effectively assessed and monitored potential threats to the rights and freedoms of the data subjects. The company only partially fulfilled its obligation to verify the selection and effectiveness of the technical and organizational measures applied. The complainant did not undertake appropriate actions to assess the adequacy of the relevant technical and organizational measures in relation to the risks, which it was obliged to do under Article 32(1) sentence 1 and Article 25(1) of Regulation 2016/679. The Provincial Administrative Court in Warsaw indicated that Regulation 2016/679 introduced an approach in which risk management is the foundation of activities related to the protection of personal data and is a continuous process. Data controllers are obliged not only to ensure compliance with the guidelines of the aforementioned regulation through a one-time implementation of organizational and technical security measures but also to ensure the continuity of monitoring the level of threats and to ensure accountability regarding the level and adequacy of the implemented safeguards.

Moreover, in the opinion of the Provincial Administrative Court, the authority correctly concluded that the complainant violated Article 5(1)(a) and Article 5(2) of Regulation 2016/679, i.e., the principles of lawfulness, fairness, and transparency as well as the principle of accountability in the processing of personal data derived from installment applications. The court found the explanations provided by the company regarding the completed data processing process from installment applications insufficient to conclude that the processing was conducted in accordance with the law. Since the legislator included the deletion of personal data in the processing of personal data, the process of data deletion by the administrator must comply with the requirements specified in Article 5 of Regulation 2016/679. Meanwhile, the process of deleting the database of installment applications carried out by the company was not preceded by any documented analysis and was not conducted based on the procedures in force in the company that define the rules and periods for deleting personal data resulting from legal provisions or the administrator's purposes.

The Provincial Administrative Court in Warsaw found that the financial penalty imposed by the administrative authority in the amount of PLN 2,830,410 fulfills the functions specified in Article 83(1) of

Regulation 2016/679, being effective, proportionate, and deterrent. The court deemed the justification for the amount of the penalty correct, emphasizing that the authority indicated the grounds on which it relied, taking into account the nature, gravity, and duration of the violation and both aggravating and mitigating circumstances regarding the imposition of this penalty.

Regarding the issue of the authority's dismissal of the complainant's request to conduct evidence from the expert's opinion, the court indicated that since the authority had sufficient evidence in the case, conducting any other evidence, in light of the established findings, was unnecessary. Having this in mind, the Provincial Administrative Court in Warsaw concluded that all raised objections, both concerning the violation of substantive law and procedural law, were unfounded and there was no grounds for considering that the authority committed other violations of the law. Therefore, the Court dismissed the complaint, deeming it not worthy of consideration. The cassation complaint against the above judgment was filed by Morele.net, challenging it in its entirety. In the content of the cassation complaint, the Company's representatives contested the judgment of the Provincial Administrative Court in Warsaw dated September 3, 2020, in case file II SA/Wa 2559/19, which dismissed the complaint against the decision of the President of the Personal Data Protection Office dated September 10, 2019, ZSPR.421.2.2019, ZSPR.405.67.2019 in its entirety and requested that the Supreme Administrative Court refer a preliminary question to the Court of Justice of the European Union analogous to the question formulated in the complaint to the Provincial Administrative Court in Warsaw dated October 16, 2019.

The Company alleged that the contested judgment violated substantive law provisions and procedural provisions that could have had a significant impact on the outcome of the case. By judgment dated February 9, 2023, case file III OSK 3945/21, the Supreme Administrative Court annulled the contested judgment and the contested decision, indicating that the first-instance Court overlooked the rights of the party arising from Article 78 of the Administrative Procedure Code, assuming that since the President of the UODO had sufficient evidence in the case, conducting the evidence requested by the party in the form of an expert opinion was unnecessary. The Provincial Court should have taken into account the precedent nature of the case, related to the scale of the violation of personal data confidentiality and the size of the activities of the Complainant, processing personal data of over 2,200,000 users. In such circumstances, as stated by the NSA, it must be questioned whether the authority - at the time of issuing the contested decision - possessed its own specialized knowledge allowing for the assessment of the adequacy of technical and organizational measures in a business activity of such a large scale.

In the opinion of the cassation Court, the possession of such specialized knowledge, necessary to replace the expert opinion with its own findings, is not determined solely by the assertion of the administrative authority. This authority should be able to substantiate that it actually possesses knowledge that not only subjectively but also objectively, and thus with the impartiality required by Article 8 § 1 of the Administrative Procedure Code, allows for an assessment of the circumstances of the case that requires specialized knowledge. In this case, it is an assessment of whether the technical and organizational measures used by Morele.net sp. z o.o. were adequate, taking into account the state of technical knowledge, the cost of implementation, and the nature, scope, context, and purposes of processing as well as the risk of infringement of the rights or freedoms of individuals with varying probabilities of occurrence and severity of the threat. The NSA expressed doubts as to whether the authority in its previous practice (i.e., in 2019) conducted proceedings in a similar category of cases, which would allow for the establishment of an appropriate standard of security measures corresponding to the nature, scope, and context of processing. The authority could not effectively invoke the specialized knowledge of the Office's employees, as it related to the previous legal state, within which no solutions such as those in Article 32 of Regulation 2016/679 (the lack of specification of the appropriate standard of required technical measures) were applied. The Supreme Administrative Court found the authority's explanations unconvincing, that the model of personal data protection based on the assumption that the measures adopted by administrators should be tailored to the threats and the nature of the processed data is not new, and that the General Inspector for Personal

Data Protection has repeatedly identified threats and obligated administrators in the form of administrative decisions to implement measures adequate to the risk. These circumstances are irrelevant to the case, considering the scale of Morele.net sp. z o.o.'s operations and the related specificity of the security measures applied to the personal data of over two million customers.

Taking the above circumstances into account, the NSA concluded that the authority violated Article 78 § 1 of the Administrative Procedure Code, which states that "[a] request by a party for the taking of evidence should be granted if the subject of the evidence is a circumstance relevant to the case." The circumstances indicated in the evidence request by Morele.net sp. z o.o. were of significant importance to the case, and therefore the request for the taking of evidence in the form of an expert opinion should have been granted by the President of the UODO. At the same time, the NSA indicated that during the control proceedings and the administrative proceedings, the President of the UODO did not produce any document constituting the conclusions from the analysis of the standard of security measures applied by Morele.net sp. z o.o., to which the party - in the absence of an expert opinion in the files - could refer during the proceedings. Meanwhile, such a solution would significantly reduce the rigor of the proceedings, within which the party only learns from the final administrative decision how the standard of security it adopted was assessed.

Furthermore, the authority violated Article 7, Article 77 § 1, and Article 80 of the Administrative Procedure Code by failing to fully establish the factual state of the case and by arbitrary, rather than free analysis of the collected evidence. This assessment resulted in a premature conclusion that Morele.net did not apply appropriate security measures for the protection of personal data. Additionally, the Supreme Administrative Court did not consider the request of Morele.net Sp. z o.o. based in Krakow to refer a request to the Court for a preliminary ruling to the Court of Justice of the European Union.

Addressing the individual allegations, the cassation Court found that the President of the UODO did not violate Article 107 § 1 point 5) of the Administrative Procedure Code. In the contested decision, he specified the administrative sanction referred to in Article 83 paragraph 3, paragraph 4 letter a) and paragraph 5 letter a) of Regulation 2016/679. The specification of the abstract

i. The general sanctioning norm consists of imposing a specific legal sanction on the addressee of the decision. The President of UODO clearly indicated which legal norm was specified, and the formulation of the decision itself does not raise any doubts for the Supreme Administrative Court.

The cassation court also accepted that the assessment of the evidence was not arbitrary, as the authority stated in the content of the decision that the Company did not take actions aimed at evaluating the selection of technical and organizational measures in terms of their adequacy to the risks. Consequently, the complainant in cassation incorrectly alleges the arbitrariness of the findings of the President of UODO, asserting that the gathered evidence indicates that the Company insufficiently assessed its ability to continuously ensure confidentiality. Similarly, it is impossible to challenge the authority's findings that the allegation of the President of UODO regarding the Company's insufficiently prompt response was justified, as despite the declaration of continuous network monitoring, the Company, based on the analysis of network traffic, was unable to determine whether data had indeed been stolen.

The Supreme Administrative Court considered the allegation regarding the violation of Article 151 of the Administrative Procedure Code (p.p.s.a.) in conjunction with Article 7 of the Administrative Code (k.p.a.), Article 77 § 1 of the k.p.a. in conjunction with Article 77 § 4 of the k.p.a., Article 80 of the k.p.a., Article 81 of the k.p.a., Article 84 § 1 of the k.p.a. in conjunction with Article 8 § 1 of the k.p.a., and Article 10 § 1 of the k.p.a., by dismissing the complaint in a situation where the authority made factual findings and assessments based on evidence not contained in the case files, to be unfounded. This allegation contests the failure to gather in the administrative proceedings the norms, guidelines, and other specialized documents cited in the decision, which was said to have led to the authority making findings based on evidence collected outside the administrative proceedings. The authority is not obliged to gather in the case files documents that, not constituting evidence, support the arguments presented in the legal justification of the decision. Consequently, the examined allegation does not

merit consideration.

The complainant in cassation, in the opinion of the Supreme Administrative Court, incorrectly raises the violation of Article 151 of the p.p.s.a. in conjunction with Article 7 of the k.p.a., Article 77 § 1 of the k.p.a., Article 80 of the k.p.a. by dismissing the complaint in a situation where the authority did not conduct a comprehensive assessment of the evidence and did not draw logical and coherent conclusions from the evidence gathered by the authority. This allegation is based on the assertion that the authority incorrectly concluded that the data leak concerned approximately 2,200,000 users.

The Supreme Administrative Court finds the allegation regarding the violation of Article 151 of the p.p.s.a. in conjunction with Article 7 of the k.p.a., Article 77 § 1 of the k.p.a., Article 80 of the k.p.a., and Article 81a of the k.p.a. by dismissing the complaint in a situation where the authority assumed that the Company did not properly collect consents for data processing before May 25, 2018, to be justified, as a proper assessment of the evidence should have led to the conclusion that this circumstance was not proven during the administrative proceedings. According to the Court, the authority incorrectly and prematurely concluded that the Company did not document the deletion of data from installment applications. During the proceedings, the Company convincingly explained that the deletion of databases was documented in the IT system logs. Consequently, the Supreme Administrative Court considers the allegation regarding the violation of Article 151 of the p.p.s.a. in conjunction with Article 107 § 1 point 6) of the k.p.a. and Article 107 § 3 of the k.p.a. by dismissing the complaint in a situation where the authority prepared the justification in an incomprehensible manner, inconsistent with the obligations imposed on the authority regarding the preparation of the justification, to be partially justified. This allegation is justified in relation to the previous allegation, i.e., in the context of accepting the "unsubstantiated assumption by the authority that since 'consents were obtained after the regulation 2016/679 came into force, and the process itself lasted from 2016 (the Company's explanations), it should be assumed that the deleted database contained data collected without a legal basis'" - point 1 letter f) of the allegation.

The cassation court partially accepted the Company's argumentation regarding the justification of the amount of the imposed financial penalty. Although the financial situation of the party is not, under Article 83 § 2 of Regulation 2016/679, a directive for the imposition of a penalty, it follows from Article 83 § 1 of Regulation 2016/679 that the administrative financial penalty should be effective, proportionate, and deterrent. In the opinion of the Supreme Administrative Court, the proportionality of the penalty should relate not only to the extent of the violation but also to the financial situation of the entity bearing legal responsibility. In this context, according to the Supreme Administrative Court, the President of UODO should have addressed the financial situation of the party and analyzed whether the amount of the financial penalty would demonstrate its proportionality in relation to the financial documents submitted by the Company. The oversight of this issue indicates a violation by the first-instance court of Article 151 of the p.p.s.a. in conjunction with Article 107 § 3 of the k.p.a. In other respects, the allegation does not merit consideration. The President of UODO thoroughly addressed the directives from Article 83 § 2 of Regulation 2016/679 and convincingly justified the amount of the imposed financial penalty in this context.

The Supreme Administrative Court considered the allegation of violation of Article 151 of the p.p.s.a. in conjunction with Article 32 paragraphs 1 and 2 of Regulation 2016/679, which consisted of assuming that Article 32 paragraphs 1 and 2 of Regulation 2016/679 imposes an obligation to apply effective technical and organizational measures, while the obligation arising from Article 32 paragraphs 1 and 2 of Regulation 2016/679 concerns the application (implementation) of appropriate measures to ensure a level of security corresponding to the risk. The authority conducted a correct interpretation of Article 32 paragraphs 1 and 2 of Regulation 2016/679 and did not assume that this provision requires that the applied measure...

be effective in every case.

The allegation regarding the violation of Article 151 of the Administrative Procedure Code (p.p.s.a.) in conjunction with Article 24(1) of Regulation 2016/679 and Article 32(1) and (2) of Regulation 2016/679 due to their improper application is deemed unfounded by the NSA, specifically regarding the



formulation of assessments concerning the adequacy/inadequacy of technical and organizational security measures without prior risk assessment, particularly by assuming that the technical and organizational security measures employed by the complainant were inadequate (i.e., insufficient according to the authority). The authority did not improperly apply the aforementioned provisions of Regulation 2016/679.

The Court also deemed the allegation of a violation by the WSA of Article 151 of the p.p.s.a. in conjunction with Article 5(2) of Regulation 2016/679 in conjunction with Article 7(1) and in conjunction with Article 11(1) of Regulation 2016/679 due to their erroneous interpretation and the assumption that the Company has an obligation to demonstrate the legality of personal data processing, despite the fact that the personal data processing process had been completed, while the provisions of Regulation 2016/679 require demonstrating accountability, including demonstrating the legal basis and the correctness of the collected consents, solely concerning the data currently processed by the data controller.

From the above justification, it clearly follows that, in the opinion of the NSA, the President of the UODO was obliged to conduct evidence from an expert opinion or to create an internal document containing conclusions from the analysis of the standard of security measures applied by Morele.net, to which the party could refer during the proceedings. In connection with the above, in execution of the NSA judgment, the President of the UODO created an internal document containing conclusions from the analysis of the standard of security measures applied by the Company, namely the document "Analysis of the technical and organizational measures applied by Morele.net Sp. z o.o. based in Krakow (hereinafter referred to as the 'Company' or 'Morele.net') affecting the occurrence of a personal data breach, prepared based on the evidence collected during the inspection conducted in the Company from January 21 to 25, 2019, reference no. ZSPR.421.2.2019, ZWAD.405.1687.2018, ZWAD.405.1689/2018, ZWAD.405.1979.2018" (hereinafter: "Analysis").

On November 28, 2023, the President of the UODO issued a decision refusing to accept the request "to allow and conduct evidence from an expert opinion possessing special knowledge in the field of information systems security, regarding the determination of technical and organizational standards of security measures in the business activities of entrepreneurs in the e-commerce sector on a scale and nature similar to that of the Company's activities in 2018; assessing whether the technical and organizational measures employed by the Company corresponded to the standards of security measures in the business activities of entrepreneurs in the e-commerce sector on a scale and nature similar to that of the Company's activities in 2018; assessing whether the technical and organizational measures employed by the Company were appropriate considering the state of technical knowledge, the cost of implementation, and the nature, scope, context, and purposes of processing as well as the risk of infringement of the rights or freedoms of individuals with varying probabilities of occurrence and severity of threat."

In a letter dated December 21, 2023, the Company presented its position and requested the exclusion of employees of the Supervisory Authority from participating in the proceedings in the matter. As indicated in the aforementioned letter, the Company disagrees with the position of the President of the UODO expressed in the decision of November 28, 2023, regarding the refusal to accept the request for the admission of evidence from an expert opinion on the matter indicated in this resolution. The "Analysis of the technical and organizational measures applied by Morele.net Sp. z o.o. based in Krakow affecting the occurrence of a personal data breach..." prepared by UODO employees on October 17, 2023, in the Company's opinion, does not constitute sufficient evidence. There are justified concerns regarding the impartiality of the authors of the Analysis as employees of the UODO. The President of the UODO did not demonstrate in any way that at the time of issuing the Analysis, he possessed his own specialized knowledge allowing him to independently assess the technical and organizational measures employed by the Company at the time of the occurrence of external attacks. In the Company's opinion, the conclusions drawn from the Analysis support the thesis of the lack of impartiality of the UODO employees who prepared it. Although the authors correctly indicated that the starting point for assessing the incident should be determining the level of risk associated with processing specific personal data (in a specific process), they did not specify what level of risk they adopted. This omission has further significant consequences, as the assessment of the implemented

technical and organizational measures cannot be conducted in isolation from the level of risk associated with processing (threats). In the Company's view, this error affects the entirety of the Analysis, effectively disqualifying it. It cannot be excluded that the source of the described omission was the lack of impartiality of the authors of the Analysis - UODO employees. In light of the above, in the Company's opinion, it has been demonstrated, as specified in Article 24 § 3 of the Code of Administrative Procedure (KPA), the likelihood of the existence of circumstances that may raise doubts about the impartiality of the employees of the Authority indicated in the request.

After reviewing all the evidence collected in the case, the President of the Personal Data Protection Office considered the following:

I. Article 5 of Regulation 2016/679 formulates principles regarding the processing of personal data that must...

to be respected by all administrators, i.e., entities that independently or jointly determine the purposes and means of processing personal data. According to Article 5(1)(f) of Regulation 2016/679, personal data must be processed in a manner that ensures appropriate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures ("confidentiality and integrity").

In accordance with the provisions of Article 24(1) of Regulation 2016/679, taking into account the nature, scope, context, and purposes of processing as well as the risk of infringement of the rights or freedoms of natural persons with varying likelihood and severity, the administrator implements appropriate technical and organizational measures to ensure that processing is performed in accordance with this regulation and to be able to demonstrate it. These measures are reviewed and updated as necessary.

According to Article 25(1), both when determining the means of processing and during the processing itself, the administrator implements appropriate technical and organizational measures designed to effectively implement the principles of data protection (data protection by design).

Pursuant to Article 32(1)(b) of Regulation 2016/679, taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of processing as well as the risk of infringement of the rights or freedoms of natural persons with varying likelihood and severity, the administrator and the processor implement appropriate technical and organizational measures to ensure a level of security appropriate to that risk, including, where appropriate, the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services, and in accordance with Article 32(1)(d) of Regulation 2016/679, regular testing, measuring, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing.

According to Article 32(2) of Regulation 2016/679, when assessing whether the level of security is appropriate, the administrator takes into account, in particular, the risks associated with processing, in particular those arising from accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or unauthorized access to personal data transmitted, stored, or otherwise processed.

The provisions of Article 24(1), Article 25(1), Article 32(1)(b) and (d), and Article 32(2) of Regulation 2016/679 thus specify the principle of confidentiality and integrity indicated in Article 5(1)(f) of Regulation 2016/679. Consequently, the matter at hand should be analyzed in terms of meeting the conditions that determine the appropriate level of technical and organizational measures to be applied.

The principle of confidentiality, the proper implementation of which ensures that data is not disclosed to unauthorized persons, has been violated in the factual circumstances of the case due to two instances of unauthorized access to the Company's employee panel and access to the database of all the Company's clients by unauthorized persons. Access to the Company's employee panel and to the data of all clients from the Company's database resulted in the materialization of the risk of infringement of the rights and freedoms of natural persons whose data is processed by the Company, in the form of a method known as phishing, aimed at obtaining data, including authentication credentials for bank accounts, by impersonating the Company in SMS messages and exploiting the fact of an order placed by a client.

According to Recital (83) of Regulation 2016/679, the administrator or processor should assess the risks inherent in processing and implement measures—such as encryption—that minimize those risks. It should therefore be noted that determining appropriate technical and organizational measures is a multi-step process. First and foremost, it is essential to determine the level of risk associated with the processing of personal data, taking into account the criteria indicated in Article 32(1) of Regulation 2016/679, and then to establish what technical and organizational measures will be appropriate to ensure a level of security commensurate with that risk. The nature and type of actions taken should directly result from the previously conducted, i.e., still in the design phase of the data protection system processed in the organization of the given administrator or processor, risk analysis. In the case of Morele.net, it was established that the risk analysis was conducted on an ad-hoc basis for individual processes, in an informal manner, which means that the Company did not demonstrate that such an analysis was conducted prior to the occurrence of the personal data breach for the resource covered by this breach.

In the assessment of the Supervisory Authority, such a manner of operation by Morele.net did not ensure adequate control over the aforementioned process in the context of ensuring the security of the personal data involved, as well as the ability to demonstrate its compliance with the provisions of Regulation 2016/679, in accordance with the accountability principle arising from Article 5(2) of Regulation 2016/679.

As already noted in the literature (P. Barta, P. Litwiński, M. Kawecki, Commentary on Article 5, in: General Regulation on Personal Data Protection. Personal Data Protection Act. Selected Sectoral Provisions. Commentary, ed. P. Litwiński, Legalis 2021), “[a]ccountability, which in particular includes the obligation to demonstrate compliance with legal provisions, consists in the opinion of the Article 29 Working Party [Opinion of 13.07.2010 No. 3/2010 on the principle of accountability].”

(WP 173), (...) ] from the following partial obligations:

- 1) the obligation to implement measures (including internal procedures) that guarantee compliance with data protection regulations in connection with their processing operations;
- 2) the obligation to prepare documentation that indicates to the data subjects and supervisory authorities what measures have been taken to ensure compliance with personal data protection regulations.

(...) In this sense, accountability should therefore be understood as a certain property of processing activities that allows for the demonstration of compliance with legal regulations concerning operations on personal data, particularly through documentation of personal data protection. The consequence of the principle of accountability is that in the event of a dispute with the data subject or with the supervisory authority, the controller should be able to present evidence that they comply with personal data protection regulations. Such evidence may primarily consist of documents describing the principles of processing and protecting personal data.

Due to the lack of a formalized risk analysis related to processing, and thus documented or otherwise recorded and presented in the form of strictly defined, precise formulations explaining and organizing the course of this process, the Company was unable to demonstrate that in implementing technical and organizational measures to ensure compliance of processing with Regulation 2016/679, as well as assessing whether the level of security of personal data is appropriate, it actually took into account the criteria described in Article 32(1) of Regulation 2016/679, including the risk of infringement of the rights or freedoms of natural persons, and the risks associated with processing, particularly those arising from accidental or unlawful destruction, loss, alteration, unauthorized disclosure, or unauthorized access to personal data, in accordance with the obligation arising from Article 32(2) of Regulation 2016/679. As emphasized by the Provincial Administrative Court in Warsaw in its judgments of May 13, 2021, case no. II SA/Wa 2129/20, and October 5, 2023, case no. II SA/Wa 502/23, “The data controller should therefore conduct a risk analysis and assess what threats it is dealing with.”

In this context, it should be noted that Regulation 2016/679 introduced an approach in which risk management is the foundation of actions related to the protection of personal data. Risk management is a continuous process that requires the data controller not only to ensure compliance with the provisions of Regulation 2016/679 through a one-time implementation of organizational and technical

security measures but also to ensure the continuity of monitoring the level of threats and to ensure accountability regarding the level and adequacy of the implemented safeguards. The obligation to ensure the security of processed data, defined among others in Article 32(1) of Regulation 2016/679, is one of the legal bases for the protection of personal data introduced by Regulation 2016/679. The applicable legal provisions do not specify a catalog of appropriate security measures, and it is the responsibility of the controller to assess this area. This provision introduces a risk-based approach while simultaneously indicating the criteria based on which the controller should select appropriate technical and organizational measures to ensure a level of security corresponding to that risk. In addition to the risk of infringement of the rights or freedoms of natural persons, the state of technical knowledge, the cost of implementation, and the nature, scope, context, and purposes of processing should also be taken into account. As indicated by the Provincial Administrative Court in its judgment of October 5, 2023, case no. II SA/Wa 502/23, "the supervisory authority is not obliged to indicate to the Controller the technical and organizational solutions that it should implement to ensure that the processing of personal data is carried out in accordance with the law. It is the responsibility of the Controller to implement these measures and then, if necessary, to demonstrate that it complies with the principles of personal data processing specified in Regulation 2016/679, in accordance with the principle of accountability (Article 5(2) of the aforementioned regulation)."

For the proper fulfillment of the obligations arising from the above-mentioned provisions of Regulation 2016/679, the Controller should therefore first conduct a risk analysis and based on it determine and implement adequate measures to ensure security in the process of processing personal data. In the event that the Controller anticipated the possibility of processing personal data in IT systems, the analysis should indicate the risks arising from the use of specific elements of the IT environment. Consequently, the analysis should foresee appropriate security measures that guarantee, above all, the ability to continuously ensure confidentiality, integrity, availability, and resilience of processing systems and services (Article 32(1)(b) of Regulation 2016/679), in order to minimize the risk of a personal data breach.

The analysis conducted during the proceedings in execution of the judgment of the Supreme Administrative Court of February 9, 2023, case no. III OSK 3945/21, showed that the case files contain evidence confirming that the Company itself admitted to insufficient data security due to the lack of encryption of certain sensitive data recorded in the database (...). The Company also admitted that technical access passwords were stored in an unencrypted database, and encryption was implemented only after the data breach was detected (...). The Company did not demonstrate that the measures it applied before the personal data breach were adequate.

#### **\*\*Technical Measures and Data Protection Violations\*\***

The technical measures were appropriate, but it was explicitly confirmed that the technical measures employed by the Company prior to the violation of personal data protection did not ensure an adequate level of protection for the processed personal data. Furthermore, the Company admitted to insufficient data security due to the lack of two-factor authentication when logging into the internal order management system (...).

It must therefore be agreed with the Company that the technical measures it employed prior to the violation of personal data protection (including the lack of two-factor authentication) did not provide an adequate level of protection for the processed personal data. It should also be taken into account that the Company did not conduct a risk analysis arising from the possibility of logging into the Panel from a public network (especially since one of the transmission media in the Company was Wi-Fi), using employee logins with the syntax (...) (which facilitated their recognition by an attacker) in connection with the scope of permissions of certain users of the Panel (related to the scope of their duties) and the users' password policy. The "Instructions for Managing the IT System" in force at the Company at the time of the inspection contains a provision regarding password parameters. (...) During the inspection, a new version of the documentation was also presented to the inspectors, namely the Personal Data Protection Policy at Morele.net Sp. z o.o. and the IT System Management Instructions at Morele.net Sp. z o.o. In the new version of the documents, existing requirements regarding password parameters and the frequency of their change were replicated.

As demonstrated in the Analysis, it is also significant that only after the personal data was stolen from Morele.net were the following actions implemented: (...)

The compilation of organizational and technical measures employed by Morele.net before and after the occurrence of the personal data protection violation confirms the Company's position that prior to the violation of personal data protection, it did not implement appropriate technical and organizational measures to ensure an adequate level of security for processing (...).

The implementation by Morele.net – after the incident occurred – of stronger authentication and identity verification was in line with, among other things, the recommendations found in the Polish Standard PN-ISO/IEC 27002:2017-06 "Information Technology - Security Techniques - Practical Guidelines for Securing Information." According to point 9.4.2 of the aforementioned standard, within the framework of the secure login procedure: "In cases where strong authentication and identity verification are required, it is recommended to use alternative authentication methods to passwords, such as: cryptographic measures, electronic cards, tokens, or biometric measures." Documents such as the standard PN-EN ISO/IEC 27001:2017-06, OWASP Top10-2017[1], and the guidelines NIST 800:63B issued in July 2017[2] in the wording applicable in 2018 indicated general recommendations regarding technical measures that may be employed, with the choice of appropriate measures depending on the risk assessment. ENISA also, in the guidelines issued on October 24, 2014, regarding security measures for processing personal data[3], recommended the use of two-step authentication mechanisms for systems that include access to personal data in cases of high risk, which is the case in the context of the Company's processing of personal data, e.g., in the context of phishing or other methods used to capture passwords. Similarly, ISACA[4] in 2018 pointed out aspects of implementing multi-factor authentication, and Microsoft already in 2016 published guidelines regarding passwords, including multi-factor login[5]. Moreover, Microsoft confirmed in 2019 that the implementation of multi-factor authentication (MFA) prevents 99.9% of unauthorized account access attacks[6].

As emphasized in the Analysis, one of the fundamental and main elements of cybersecurity is to allow access to resources and data only to authorized individuals. This can be realized, for example, through a login process that involves providing a user identifier and an element used for authentication (e.g., a password), which means identifying the user and confirming their identity. Identification in this case should be understood as assigning an identifier to a person and declaring (stating) the identity of the person by presenting the aforementioned identifier. Such an identifier uniquely identifies that person and serves as the user's electronic identity. Identification thus allows for determining "who it is," but does not confirm that the user is indeed the person who has been declared and identified.

Authentication serves this confirmation, which involves providing evidence that the user is indeed the identified person (no one is impersonating them). In specific cases, identification and authentication may occur simultaneously (e.g., when the identifier is secret, serving as a "password"), but fundamentally they are two different processes. Authorization, on the other hand, is understood as the process of granting specific permissions that the correctly identified and authenticated person will be able to use. Authentication techniques can generally be divided into three groups based on verification: "what you know" (password/PIN); "what you have" (hardware token, e.g., electronic card, phone); "what you are" (biometric feature). There are also "mixed" techniques – using a hardware token for identification requires unlocking it by providing a PIN code or biometric data, which are verified by the token's processor. It is widely accepted that single-factor authentication is based on one element: "what you know" or "what you have."

you", while the combination of these two elements is referred to as "multifactor authentication" (MFA). Multifactor authentication, alongside the biometric feature-based authentication ("what you have" or "who you are"), falls under the category of "strong authentication" [7]. In the case of the breach that occurred at Morele.net, it should be noted that the use of a username and password to log into the administrative panel constituted a basic security measure, but was not sufficient on its own to ensure complete security. It is important to point out that there were and still are many advanced threats, such as brute force attacks, phishing, keylogging, or the use of weak passwords, which can allow unauthorized individuals access to the administrative panel. To enhance security levels, it is

recommended to implement additional security mechanisms, such as: role-based access control (assigning appropriate permissions and roles to employees can limit access to specific functions and data according to their responsibilities, thereby preventing unauthorized access to confidential information); activity monitoring (the system should log and monitor employee activity in the administrative panel, allowing for the detection of unusual or suspicious activities, such as logging in at atypical hours or attempts to access prohibited areas); IP restrictions (restrictions can be set at the level of IP addresses that have access to the administrative panel, allowing only specific IP addresses or ranges of IP addresses to log in, which can enhance security by limiting potential external threats); security audits (regularly conducting security audits can help identify potential security gaps and ensure compliance with best practices); employee training; multi-level authentication. It is also extremely important to regularly review and update these security measures in response to changing threats. The basic knowledge indicated above should be known to those dealing with general IT security issues and should be taken into account when creating and securing the IT infrastructure used for processing information (including personal data).

Considering the above, when assessing the technical and organizational measures applied by Morele.net that influenced the occurrence of the personal data breach, it cannot be overlooked that the breach occurred as a result of unauthorized access to an employee's account by an unauthorized person who possessed the username and password for the aforementioned account. It is significant that the Company could not explain how the login data was compromised. Furthermore, in the explanations provided on January 25, 2019, Morele.net stated that "the Company does not connect the incident of (...) November 2018 with the message received from the blackmailer" (...). At the same time, the Company did not present any evidence to support the above statement, nor did it indicate how the personal data could have been obtained from the customer database.

The above allows for the conclusion that the network security measures employed by Morele.net and the analysis of network traffic were insufficient. Monitoring network traffic is a crucial element aimed at detecting unauthorized access to data, including its retrieval by an unauthorized person. Network traffic control can help notice, among other things, incorrect device configurations, data transfer issues, attempts to install "foreign" software (so-called shadow IT). This control increases the chances of detecting third-party interference in information systems and contributes to preventing personal data breaches.

As the Company indicated, the first signals of data theft came from customers of the service and a person who claimed to have downloaded the customer database. Consequently, it should be acknowledged that the Company – contrary to the statements made during the proceedings – did not monitor the network and its production environment, nor did it respond to incidents in the system 24/7. Moreover, the collected evidence confirms that the Company was uncertain whether and what had actually been stolen from its servers, even though data reading from the order cards was occurring from the account of one of the employees also after working hours. In the communication sent to customers after the personal data breach, Morele.net informs, among other things, "Dear Customer, there has been unauthorized access to the personal data of our Customers: email address, phone number, first and last name (if provided), and password in the form of an encrypted string (hash). There is a risk that this also concerns your data [...]" (...). The statement that "there is a risk that this also concerns your data" indicates that the Company was unable to determine which customers were affected by the personal data breach. Only after implementing detailed system monitoring on (...) November 2018 was it possible to detect unauthorized data retrieval of customers. As a result of the conducted explanatory proceedings, among other things, a "Report after the database theft" was created, which indicates that increased data transfer occurred on (...) - (...) October 2018 (two versions of the report provided by the Company were attached to the inspection protocol). In one version of the document, the Company cites a possible hacking attack as the cause of the increased data transfer (...), while in the other, the integration of Morele.net with (...). Verification of the above reports – including the noted increased data transfer – also calls into question the date of the start of the personal data breach provided by...

The Company confirms the ineffectiveness of monitoring network traffic and the anomalies that occurred. It should be noted that regular monitoring of user account activity would have enabled the detection of attempts at unauthorized access. Configuring alerts to inform about any unusual activities, such as attempts to log in from a different location or at an unusual time, could assist in this. In this regard, the allegation concerning the insufficiently quick response is justified, as despite the declaration of constant network monitoring, the Company, based on the analysis of network traffic, was unable to determine whether data had actually been stolen, what data it was, and if it had been downloaded, when it occurred. Insufficient monitoring of user activity prior to the incident is also confirmed by the actions taken by Morele.net after its occurrence – the Company admitted that it only implemented a tool to track system traffic after the personal data had been stolen.

Taking these actions after the breach of personal data protection clearly confirms that, in the Company's own assessment, they were necessary to ensure an appropriate level of security for the personal data processed by it. In this context, it should also be pointed out that the Provincial Administrative Court in Warsaw, in its judgment of August 26, 2020, case no. II SA/Wa 2826/19, stated that "(...) activities of a technical-organizational nature fall within the competence of the personal data administrator, but they cannot be selected in a completely free and voluntary manner, without taking into account the degree of risk and the nature of the protected personal data."

According to Article 32(1)(d) of Regulation 2016/679, the administrator and the processor are obliged to regularly test, measure, and evaluate the effectiveness of technical and organizational measures to ensure the security of processing. This also includes verifying both the selection and the level of effectiveness of the technical measures used, and the comprehensiveness of this verification should be assessed in light of adequacy to risks and proportionality in relation to the state of technical knowledge, implementation costs, and the nature, scope, context, and purposes of processing.

The Company partially fulfilled this obligation by only verifying the level of effectiveness of the implemented security measures in terms of known vulnerabilities in the deployed software – as indicated by security audits of the existing information systems used for processing the Company's customer data conducted from (...) August to (...) September 2016 and from (...) May to (...) June 2017. However, there is no evidence that the Company conducted security audits or otherwise fulfilled its obligations as an administrator in this regard from the moment it began applying Regulation 2016/679, i.e., from May 25, 2018, until the occurrence of the personal data breach. As indicated by the Provincial Administrative Court in Warsaw in its judgment of June 6, 2023, case no. II SA/Wa 1939/22, "(...) the obligation to regularly test technical and organizational measures securing the processing of personal data to ensure a level of security corresponding to the risk, in the sense of Article 32(1) introductory sentence of the GDPR, directly results from the wording of point (d) of the indicated Article 32(1), while the obligation to document actions in this regard is established by the principle of accountability (Article 5(2) of the GDPR)." Similarly, the Provincial Administrative Court in Warsaw stated in its judgment of June 21, 2023, case no. II SA/Wa 150/23, that "It should be emphasized that regular testing, measuring, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing is a fundamental obligation of every administrator and processor arising from Article 32(1)(d) of the GDPR. Therefore, the administrator is obliged to verify both the selection and the level of effectiveness of the technical measures used at every stage of processing. The comprehensiveness of this verification should be assessed in light of adequacy to risks and proportionality in relation to the state of technical knowledge, implementation costs, and the nature, scope, context, and purposes of processing."

The above findings indicate that the Company inadequately assessed its ability to continuously ensure confidentiality and did not take into account the risks associated with unauthorized access to the panel, and consequently did not implement appropriate technical and organizational measures to prevent this. Gaining access to the panel and the Company's customer data resulted in the materialization of the risk of violating the rights or freedoms of individuals whose data is processed by the Company, through attempts to fraudulently obtain data, including authentication details for bank accounts (phishing), by impersonating the Company, using the fact that an order had been placed by a

customer. Particularly since the method of encrypting the store's user passwords also proved ineffective, as verified by the Company's customers using publicly available tools to check whether data had been disclosed, indicated a leak from Morele.net of data concerning, among others, email addresses and passwords. The actions taken by the Company, consisting of introducing two-factor authentication, were a response to another unauthorized access to data through an employee's account and indicate that the Administrator (but only after the occurrence of the personal data breach) conducted an analysis of the technical measures applied (including those concerning the security of user accounts), identified weaknesses in the security measures used, and recognized the necessity of their removal.

It should be emphasized, however, that conducting a risk analysis prior to a personal data breach concerning the method of logging into the panel and, as a result, increasing the level of security could have prevented the occurrence of this breach or at least minimized its effects. Through a properly conducted risk analysis, the Company could have obtained or updated information regarding the resources at its disposal. This would have allowed for the identification of potential negative factors affecting a given resource or process (such as human factors, organizational changes, technical and organizational changes), and subsequently for the detection of gaps and vulnerabilities (including through the execution of penetration tests). Recommendations regarding risk management in information security can be found, among others, in the standards PN-ISO/IEC 27005 and PN-ISO-31000, where the above issues have been specified.

According to Article 33(5) of Regulation 2016/679, the data controller is obliged to document all personal data breaches, including the circumstances of the breach, its effects, and the remedial actions taken. This documentation must allow the supervisory authority to verify compliance with this article. Furthermore, the guidelines adopted on March 28, 2023, by the EROD titled "Guidelines 9/2022 on the reporting of personal data breaches under the GDPR" indicate that it is the controller who determines the method and structure of documenting breaches; however, there are certain key elements regarding the recorded information that must be included in every case. They should include the effects and consequences of the breach as well as the remedial actions taken by the controller.

It should be noted that in the Company, since (...).05.2018, the "Data Protection Security Policy of Morele.net, ul. Fabryczna 20A, 31-553 Kraków" and the "Information System Management Instruction of Morele.net, ul. Fabryczna 20A, 31-553 Kraków" were in force.

According to Chapter 6, Section 1, letter D of the "Data Protection Security Policy of Morele.net, ul. Fabryczna 20A, 31-553 Kraków" (...) the Information Systems Administrator, DPO, ADO documents each case of data security breach and prepares a report according to the template constituting Annex 6 to the Policy (...). Meanwhile, neither during the control proceedings nor during the administrative proceedings did the Company present the President of the Personal Data Protection Office with a completed report, which, in conjunction with other evidence, clearly indicates that the Data Protection Security Policy was not adhered to at Morele.net.

According to Chapter 9, Section 2 of the "Information System Management Instruction of Morele.net, ul. Fabryczna 20A, 31-553 Kraków," upon receiving notification of a breach of the information system's security, the ADO should immediately, among other things, take actions to secure the system against further breaches, as well as assess the degree of the employee's contribution to the occurrence of the data protection obligation breach (...). Considering that unauthorized access to employee accounts occurred twice in the same manner, there are grounds to conclude that from the time of the first breach ([...] November 2018) until the second breach ([...] 12.2018), the Company did not take effective measures to secure the system against further breaches, thus acting contrary to its own "Information System Management Instruction of Morele.net, ul. Fabryczna 20A, 31-553 Kraków." Importantly, the Company – despite stating that the breach occurred as a result of unauthorized access to the employees' system accounts – did not present any evidence confirming the assessment of the degree of the employee's contribution to the occurrence of the data protection obligation breach. It should also be noted that due to the prohibition on employees sharing access passwords, even after they have expired (...) determining by Morele.net how a third party first gained access to an employee's system



account would have enabled the Company to implement appropriate measures to secure the system, thereby eliminating the possibility of another personal data breach.

It should also be stated that the “Information System Management Instruction of Morele.net, ul. Fabryczna 20A, 31-553 Kraków,” in force since (...).05.2018, is inconsistent with the regulation of the Minister of the Interior and Administration of April 29, 2004, regarding the documentation of personal data processing and the technical and organizational conditions that devices and information systems used for processing personal data should meet (Dz.U.2004.100.1024), which was in force until 06.02.2019. According to Annex A, Section II, paragraphs 1 and 2, letters a) and b) of the aforementioned regulation, the information system used for processing personal data was required to implement access control mechanisms to that data, and if access to the data processed in the information system was held by at least two persons, it was necessary to ensure that a separate identifier was recorded for each user in that system, and access to the data was only possible after entering the identifier and authentication. Meanwhile, in Chapter 4.2, Section 1, letter b) of the “Information System Management Instruction of Morele.net, ul. Fabryczna 20A, 31-553 Kraków” (...) the Company stated that a login and password is a method of authentication to the personal data processing system only if the system has a built-in authentication mechanism. Such a solution was also replicated in point 4.7 of the draft new “Personal Data Protection Policy.”

\*\*\*“Morele.net Sp. z o.o.” (...). Allowing the processing of personal data in systems that do not require authentication (or using insufficient authentication), the Company did not implement necessary safeguards, which violated Article 25(1) of Regulation 2016/679.\*\*

Considering the above, it should be stated that the technical and organizational measures employed by Morele.net were not appropriate, taking into account the state of technical knowledge, the cost of implementation, as well as the nature, scope, context, and purposes of processing and the risk of infringement of the rights or freedoms of natural persons with varying probabilities of occurrence and severity of threat. The Company failed to fulfill its obligation to ensure appropriate technical and organizational security measures for the processed data, guaranteeing the ability to continuously ensure confidentiality, integrity, availability, and resilience of processing systems and services, as well as the obligation to regularly test, measure, and evaluate the effectiveness of these measures, thereby leading to a violation of the principle of confidentiality and integrity expressed in Article 5(1)(f) of Regulation 2016/679, reflected in the form of obligations specified in Article 24(1), Article 25(1), Article 32(1)(b) and (d), and Article 32(2) of Regulation 2016/679, and consequently to a violation of the principle of accountability referred to in Article 5(2) of Regulation 2016/679. As stated in the judgment of the Provincial Administrative Court in Warsaw dated February 10, 2021, case no. II SA/Wa 2378/20, “The principle of accountability is therefore based on the legal responsibility of the administrator for properly fulfilling obligations and imposes on them the duty to demonstrate, both to the supervisory authority and to the data subject, evidence of compliance with all principles of data processing.” Similarly, the issue of the principle of accountability is interpreted by the Provincial Administrative Court in Warsaw in the judgment dated August 26, 2020, case no. II SA/Wa 2826/19, “Considering the entirety of the norms of Regulation 2016/679, it should be emphasized that the administrator has significant discretion regarding the safeguards employed, while at the same time bearing responsibility for violations of personal data protection regulations. From the principle of accountability, it directly follows that it is the data administrator who should demonstrate, and thus prove, that they comply with the provisions specified in Article 5(1) of Regulation 2016/679.”

It should be noted that “appropriate” technical and organizational measures under Article 32(1) of Regulation 2016/679 are measures that are not necessarily effective in every case but are those that could be objectively required from a given entity (administrator or processor) at the time and under the circumstances of access to personal data. The evidence collected during the proceedings confirms that, in particular, data encryption stored in the database and two-factor authentication when logging into the internal order management system could have been objectively required from Morele.net at the time and under the circumstances of access to personal data, especially since the Company promptly implemented these technical measures immediately after the disclosure of security incidents,

thereby admitting that it was a mistake not to have applied them earlier. As indicated by the Provincial Administrative Court in the judgment dated August 26, 2020, case no. II SA/Wa 2826/19, "This provision [Article 32(1)] does not require the data administrator to implement any technical and organizational measures that are to constitute measures for the protection of personal data, but requires the implementation of adequate measures. Such adequacy should be assessed in terms of the manner and purpose for which personal data is processed, but the risks associated with the processing of such personal data, which may vary in severity, should also be taken into account." This court also emphasized in the aforementioned judgment that "The adopted measures must be effective; in specific cases, some measures will have to be measures that mitigate low risk, while others must mitigate high risk; however, it is important that all measures (as well as each one individually) are adequate and proportional to the degree of risk."

In light of the above, it should be emphasized that the earlier introduction by Morele.net of additional access security measures to the employee panel, regular monitoring of network traffic, and adherence to its own security policies and instructions would significantly reduce the risk of unauthorized access to the Company's IT system, and consequently to the personal data of Morele.net customers. It should also be emphasized, following the judgment of the Supreme Administrative Court dated February 9, 2023, case no. III OSK 3945/21, that "the administrator is subject to administrative sanctions not for the fact that a violation of personal data protection occurred in their organization, but for failing to ensure an adequate standard of security for the processed personal data (...)". Furthermore, the Provincial Administrative Court in Warsaw, in the justification of the judgment dated November 15, 2023, case no. II SA/Wa 552/23, indicated that "(...) the authority correctly decoded the concept of 'data confidentiality' as a certain property that ensures that data will not be disclosed to unauthorized entities. This can be achieved, among other things, by applying technical and organizational measures that are adequate to the scope of data, the context of processing, and the identified risks."

Assessing the circumstances of the infringement of the provisions of Regulation 2016/679, it should be emphasized that when applying the provisions of Regulation 2016/679, it should be borne in mind that the purpose of this regulation (expressed in Article 1(2)) is to protect the fundamental rights and freedoms of natural persons, in particular their right to the protection of personal data, and that the protection of natural persons in relation to the processing of personal data is one of the fundamental rights.

first paragraph 1 of the preamble). In the event of any doubts, for example, regarding the performance of obligations by the administrators - not only in situations where there has been a breach of personal data protection but also in the development of technical and organizational security measures to prevent such breaches - these values must be taken into account first and foremost.

Taking into account the above findings and the identified violations of the provisions of Regulation 2016/679, the President of the UODO, exercising the authority granted to him under Article 58(2)(i) of Regulation 2016/679, according to which each supervisory authority has the power to impose, in addition to or instead of other corrective measures provided for in Article 58(2)(a)-(h) and (j) of this Regulation, an administrative fine pursuant to Article 83(4)(a) and (5)(a) of Regulation 2016/679, having regard to the circumstances established in the proceedings, determined that in the case at hand there were grounds justifying the imposition of an administrative fine on the Administrator.

According to Article 83(4)(a) of Regulation 2016/679, violations of the provisions concerning the obligations of the administrator and the processor, referred to in Articles 8, 11, 25-39, and 42 and 43, are subject, according to paragraph 2, to an administrative fine of up to 10,000,000 EUR, and in the case of an enterprise - up to 2% of its total annual worldwide turnover from the previous financial year, with the higher amount applying.

According to Article 83(5)(a) of Regulation 2016/679, violations of the provisions concerning the fundamental principles of processing, including the conditions for consent, referred to in Articles 5, 6, 7, and 9, are subject, according to paragraph 2, to an administrative fine of up to 20,000,000 EUR, and in the case of an enterprise - up to 4% of its total annual worldwide turnover from the previous financial year, with the higher amount applying.

Article 83(3) of Regulation 2016/679 states that if the administrator or processor intentionally or unintentionally violates several provisions of this Regulation within the same or related processing operations, the total amount of the administrative fine shall not exceed the amount of the fine for the most serious violation.

In this case, the administrative fine imposed on the Company was for violations of Article 25(1), Article 32(1)(b) and (d), and Article 32(2) of Regulation 2016/679 based on the aforementioned Article 83(4)(a) of Regulation 2016/679, while for the violation of Article 5(1)(f) and Article 5(2) of Regulation 2016/679 - based on Article 83(5)(a) of that Regulation. At the same time, the administrative fine in the amount of 3,819,960 PLN (in words: three million eight hundred nineteen thousand nine hundred sixty PLN), imposed on Morele.net for the violation of all the above provisions - in accordance with Article 83(3) of Regulation 2016/679 - does not exceed the amount of the fine for the most serious violation identified in this case, namely the violation of Article 5(1)(f) and Article 5(2) of Regulation 2016/679, which, according to Article 83(5)(a) of Regulation 2016/679, is subject to an administrative fine of up to 20,000,000 EUR, and in the case of an enterprise - up to 4% of its total annual worldwide turnover from the previous financial year.

In deciding to impose an administrative fine, the President of the UODO - in accordance with the provisions of Article 83(2)(a) - (k) of Regulation 2016/679 - took into account the following circumstances of the case, which necessitate the application of this type of sanction in this case and which have an aggravating effect on the amount of the imposed administrative fine:

1. The nature, gravity, and duration of the violation, taking into account the nature, scope, or purpose of the processing, the number of affected individuals whose data are concerned, and the size of the damage suffered by them (Article 83(2)(a) of Regulation 2016/679).

The Company failed to fulfill its obligation to implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk of unauthorized access to the personal data of its customers, which resulted in two instances of unauthorized access to the Company's employee panel by unauthorized person(s), and consequently also access to the database of all the Company's customers, totaling approximately 2,200,000 (about two million two hundred thousand) individuals; thus, the actions taken by the Company prior to the occurrence of the personal data breach aimed at ensuring the security of data processing must be considered ineffective, as they did not contribute to eliminating or reducing the risk of violation of the rights or freedoms of natural persons.

The violation identified in this case of Article 5(1)(f) in conjunction with Article 32(1)(b) and (d) in conjunction with Article 32(2) of Regulation 2016/679, and consequently the violation of Article 5(2) of Regulation 2016/679, related to the unauthorized access to the Company's employee panel by unauthorized person(s), and consequently also access to the Company's customer database, is of significant weight and serious nature, as it creates a high risk of negative factual and legal consequences for approximately 2,200,000 (about two million two hundred thousand) individuals whose data were accessed by unauthorized person(s), with the important note that due to the two instances of security breaches of the Company's information system, in the case of 600 (six hundred) individuals, this risk is proportionally greater.

It should be emphasized that the violation by the Company...

**\*\*Obligations to apply appropriate measures ensuring the security of processed data before making it available to unauthorized persons, entails not only a potential but a real possibility of these data being used by third parties without the knowledge and against the will of the individuals to whom the data pertains, in violation of the provisions of Regulation 2016/679.\*\***

A significant impact on the severity of the violation is also the circumstance that the Company, processing personal data in a professional manner as part of its activities, bears greater responsibility and has higher requirements than an entity that processes personal data as part of incidental or minor activities. By conducting commercial activities and collecting data via the Internet, the Company, as the

administrator of this data, should take all necessary actions and exercise due diligence in selecting technical and organizational measures that ensure the security and confidentiality of the data. Meanwhile, the findings made by the President of the Personal Data Protection Office (UODO) demonstrate that the Company did not meet this obligation at the time the identified violations occurred.

The violation of the aforementioned provisions of Regulation 2016/679 lasted at least from (...) May 2018 to (...) December 2018 (i.e., until the Company implemented additional technical safeguards). Unauthorized access to data of approximately 2,200,000 (about two million two hundred thousand) individuals should be assessed strictly due to the nature, significant weight, and scope of the violation, as well as its possible long-term consequences for the data subjects.

There is no evidence that the individuals whose data were affected suffered material damage; however, the mere breach of data confidentiality constitutes non-material damage (harm); individuals whose data were accessed unlawfully may at least feel fear of losing control over their personal data, identity theft, or identity fraud, or finally, fear of financial loss. As indicated by the District Court in Warsaw in its judgment of August 6, 2020, case file XXV C 2596/19, fear, and thus the loss of security, constitutes a real non-material damage associated with the obligation to remedy it. Furthermore, the Court of Justice of the European Union in its ruling of December 14, 2023, regarding Natsionalna agentsia za prihodite (C-340/21) emphasized that "Article 82(1) of the GDPR should be interpreted in such a way that the fear of potential misuse of personal data by third parties, which the data subject experiences as a result of a breach of this regulation, can in itself constitute 'non-material damage' within the meaning of this provision."

#### **\*\*2. Unintentional nature of the violation (Article 83(2)(b) of Regulation 2016/679)\*\***

The violation of Article 5(1)(f) and (2), Article 32(1)(b) and (d), and Article 32(2) of Regulation 2016/679 occurred due to the Company's failure to exercise due diligence and undoubtedly had an unintentional character; however, the Company, as the administrator, bears responsibility for the identified irregularities in the data processing process. Primarily, due to the failure to conduct a formalized risk analysis related to processing, thus documented or otherwise recorded, and captured in the form of strictly defined, precise formulations explaining and organizing the course of this process, the Company was unable to demonstrate that by implementing technical and organizational measures to ensure compliance with Regulation 2016/679, it also assessed whether the level of security of personal data was adequate. The circumstance that the Company, despite declaring to monitor the network system and respond in a 24/7 system (twenty-four hours a day, seven days a week), did not detect increased traffic on the server's network gateway and did not take any remedial actions to prevent access to the data of approximately 2,200,000 (about two million two hundred thousand) individuals who are the Company's clients deserves particularly severe criticism. In this context, the Company's negligence should be regarded as gross.

In deciding to impose an administrative monetary penalty, the President of the UODO took into account the following circumstances of the case that mitigate the severity of the imposed administrative monetary penalty:

Actions taken by the administrator to minimize the damage suffered by the individuals whose data were affected (Article 83(2)(c) of Regulation 2016/679). The Company took actions aimed at minimizing the damage suffered by individuals whose data were included in the data protection breach by informing these individuals about the breach of personal data protection by sending them an email containing a notification of unauthorized access to the customer database. Considering that, due to the scope of personal data covered by the data protection breach, there was no high risk of infringement of the rights or freedoms of these individuals necessitating such notification, the above action by the Company deserves approval as an action exceeding the ordinary fulfillment of the legal obligation incumbent upon the administrator.

Other circumstances, as indicated in Article 83(2) of Regulation 2016/679, after assessing their impact on the identified violation in this case, were deemed neutral by the President of the UODO in his

assessment, meaning they had neither an aggravating nor a mitigating effect on the amount of the imposed administrative monetary penalty.

1. Degree of responsibility of the administrator considering technical measures of the regulation – obligatory. Therefore, the absence of such codes or mechanisms cannot be considered as an aggravating or mitigating circumstance in this case.

8. The nature, gravity, and duration of the infringement (art. 83(2)(k) of Regulation 2016/679). The infringement committed by the Company is serious, as it involved unauthorized access to personal data of individuals, which could lead to significant risks to their rights and freedoms. The duration of the infringement was also considerable, as it persisted until the Company reported the breach. This factor weighs heavily in the assessment of the infringement.

9. The intentional or negligent character of the infringement (art. 83(2)(l) of Regulation 2016/679). The supervisory authority found that the Company acted negligently in failing to implement appropriate technical and organizational measures to protect personal data. This negligence is a significant factor in determining the severity of the administrative fine imposed.

10. Any other aggravating or mitigating factors applicable to the circumstances of the case (art. 83(2)(m) of Regulation 2016/679).

No additional aggravating factors were identified in this case. However, the Company's lack of prior infringements and its cooperation during the proceedings were noted as mitigating factors, although they did not significantly alter the outcome of the assessment.

In conclusion, the supervisory authority determined that the Company had violated Articles 25 and 32 of Regulation 2016/679 and imposed an administrative fine based on the factors outlined above. The decision reflects the seriousness of the infringement and the need to ensure compliance with data protection regulations.

Regulation 2016/679 – mandatory for administrators, therefore the circumstance of their non-application cannot be considered detrimental in this case. However, the circumstance of adopting and applying such instruments as means guaranteeing a higher than standard level of protection for personal data processing could be taken into account in its favor.

8. Any other aggravating or mitigating factors applicable to the circumstances of the case, such as financial benefits obtained directly or indirectly in connection with the violation or avoidance of loss (Article 83(2)(k) of Regulation 2016/679).

The President of the UODO did not find that the Company derived any financial benefits or avoided such losses in connection with the violation. Therefore, there are no grounds to treat this circumstance as aggravating. The establishment of measurable financial benefits resulting from the violation of the provisions of Regulation 2016/679 should be assessed very negatively. The absence of such benefits, as a natural state independent of the violation and its effects, is a circumstance that inherently cannot be mitigating. This interpretation is confirmed by the very wording of Article 83(2)(k) of Regulation 2016/679, which requires the supervisory authority to pay due attention to the benefits "obtained" – that occurred on the part of the entity committing the violation.

The President of the UODO, having comprehensively considered the matter, did not record any circumstances other than those described above that could affect the assessment of the violation and the amount of the imposed administrative monetary penalty.

Taking into account all the circumstances discussed above, the President of the UODO concluded that imposing an administrative monetary penalty on the Company is necessary and justified by the weight, nature, and scope of the violations attributed to the Company. It should be stated that the application of any other corrective measure provided for in Article 58(2) of Regulation 2016/679, particularly merely issuing a reprimand (Article 58(2)(b) of Regulation 2016/679), would not be proportional to the identified irregularities in the processing of personal data and would not guarantee that the Company would not commit further negligence in the future.

Regarding the amount of the administrative monetary penalty imposed on the Company, it should be noted that in the established circumstances of this case, in light of the violation of several provisions of Regulation 2016/679, namely the principle of confidentiality and integrity, expressed in Article 5(1)(f) of Regulation 2016/679, and reflected in the form of obligations specified in Article 24(1), Article 25(1), Article 32(1)(b) and (d), and Article 32(2) of Regulation 2016/679, and consequently Article 5(2) of Regulation 2016/679, both Article 83(4)(a) of Regulation 2016/679, which provides for the possibility of imposing an administrative monetary penalty of up to EUR 10,000,000 (in the case of an enterprise - up to 2% of its total annual worldwide turnover from the previous financial year) for violations of the administrator's obligations referred to in Articles 25 and 32 of Regulation 2016/679, as well as Article 83(5)(a) of Regulation 2016/679, according to which violations of, among others, the fundamental principles of processing referred to in Article 5 of this Regulation are subject to an administrative monetary penalty of up to EUR 20,000,000 (in the case of an enterprise - up to 4% of its total annual worldwide turnover from the previous financial year, with the higher amount applying).

In the opinion of the supervisory authority, the administrative monetary penalty imposed fulfills, in the established circumstances of this case, the functions referred to in Article 83(1) of Regulation 2016/679, i.e., it will be effective, proportional, and deterrent in this individual case.

According to the President of the UODO, the administrative monetary penalty imposed on the Company will be effective, as it will lead to a state in which it will implement such technical and organizational measures that ensure a level of security for the processed data corresponding to the risk of violation of the rights or freedoms of the data subjects and the severity of the threats associated with the processing of such personal data, particularly when using information systems. The effectiveness of the penalty is thus equivalent to the guarantee that the Company, from the moment of concluding this proceeding, will approach the requirements set by data protection regulations with the utmost diligence.

The administrative monetary penalty imposed is also proportional to the identified violation, particularly in terms of its severity, impact, the scope of affected individuals, and the risk of negative consequences that they may suffer in connection with the violation. In the opinion of the President of the UODO, the imposed administrative monetary penalty has been set at a level that, on the one hand, constitutes an adequate response from the supervisory authority to the degree of violation of obligations by the Company, while not causing, on the other hand, a situation in which the necessity of its payment would lead to negative consequences in the form of a significant deterioration of the Company's financial situation. In the opinion of the President of the UODO, the Company should – and is capable of – bearing the consequences of its negligence in the area of data protection, which is why he considers the imposition of a penalty in the amount of PLN 3,819,960 (in words: three million eight hundred nineteen thousand nine hundred sixty PLN) to be fully justified.

In the opinion of the supervisory authority, the administrative monetary penalty will also serve a repressive function in these specific circumstances, as it will constitute...

will be the response to the violation by the Company of the provisions of Regulation 2016/679, but also preventive, contributing to the prevention of future violations of the University's obligations arising from the provisions on the protection of personal data. At the same time, the penalty will be effective (achieving the goal of punishing the administrator for the most serious violation with serious consequences) and deterrent for the future (as it will lead to a state in which the Company will implement such technical and organizational measures that ensure the processed data a level of security corresponding to the risk of violation of the rights and freedoms of the data subjects and the severity of the threats accompanying the processing of such personal data). The effectiveness of the penalty is therefore equivalent to the guarantee that the Company will approach the requirements set by the provisions on the protection of personal data with the utmost diligence.

According to the President of the UODO, the administrative monetary penalty applied meets, in the established circumstances of this case, the criteria referred to in Article 83 of Regulation 2016/679, due to the seriousness of the identified violations in the context of the fundamental requirements and principles of Regulation 2016/679, including in particular the principle of confidentiality and integrity

expressed in Article 5(1)(f) of Regulation 2016/679 and the principle of accountability referred to in Article 5(2) of Regulation 2016/679. The purpose of the imposed penalty is to ensure future compliance by the Company with the provisions of Regulation 2016/679.

Finally, it is necessary to indicate that in determining the amount of the administrative monetary penalty in this case, the President of the UODO applied the methodology adopted by the European Data Protection Board in Guidelines 04/2022 on calculating administrative monetary penalties under the GDPR adopted on May 24, 2023 (hereinafter referred to as "Guidelines 04/2022"). According to the guidance presented in this document:

The President of the UODO categorized the identified violations of the provisions of Regulation 2016/679 in this case (see Chapter 4.1 of Guidelines 04/2022). Among the provisions of Regulation 2016/679 violated by the Company are the provisions of Article 5(1)(f) and Article 5(2) of Regulation 2016/679, which define the fundamental principles of processing. Violations of these provisions fall – according to Article 83(5)(a) of Regulation 2016/679 – into the category of violations subject to a higher penalty from the two dimensions of penalties provided for in Regulation 2016/679 (with a maximum amount of up to EUR 20,000,000 or up to 4% of the total annual turnover of the enterprise from the previous financial year). They are therefore in abstracto more serious than other violations (indicated in Article 83(4) of Regulation 2016/679).

The President of the UODO assessed the violations identified in this case (in particular, violations of the fundamental principles of processing) as violations of high seriousness (see Chapter 4.2 of Guidelines 04/2022). In this assessment, the criteria among those listed in Article 83(2) of Regulation 2016/679 that relate to the subject matter of the violations (constituting the "seriousness" of the violation) were taken into account, namely: the nature, gravity, and duration of the violations (Article 83(2)(a) of Regulation 2016/679), the intentional or unintentional nature of the violations (Article 83(2)(b) of Regulation 2016/679), and the categories of personal data affected by the violations (Article 83(2)(g) of Regulation 2016/679). A detailed assessment of these circumstances has been presented above. It should be noted that considering their cumulative impact on the assessment of the violation identified in this case taken as a whole leads to the conclusion that the level of its seriousness (understood in accordance with Guidelines 04/2022) is high. The consequence of this is the adoption – as the starting amount for calculating the penalty – of a value falling within the range of 20% to 100% of the maximum penalty that can be imposed on the Company, that is – considering the limit specified in Article 83(5) of Regulation 2016/679 – from the amount of EUR 4,000,000 to the amount of EUR 20,000,000 (see Subchapter 4.2.4 of Guidelines 04/2022). The President of the UODO considered the starting amount of EUR 5,000,000 (equivalent to PLN 23,580,000) to be appropriate and justified by the circumstances of this case.

The President of the UODO adjusted the starting amount corresponding to the high seriousness of the identified violation to the Company's turnover as a measure of its size and economic strength (see Chapter 4.3 of Guidelines 04/2022). According to Guidelines 04/2022, in the case of enterprises with an annual turnover of EUR 100-250 million, the supervisory authority may consider making further calculations of the penalty amount based on a value falling within the range of 15% to 50% of the starting amount. Given that the Company's turnover in the last reporting year (ending in (...) March 2023) amounted to PLN 1,041,454,000, which is approximately EUR 221 million (according to the average EUR exchange rate on January 30, 2023), the President of the UODO deemed it appropriate to adjust the amount subject to calculations to a value corresponding to 45% of the starting amount, that is to the amount of EUR 2,250,000 (equivalent to PLN 10,611,000).

The President of the UODO assessed the impact on the identified violation of the remaining circumstances (besides those taken into account above in the assessment of the seriousness of the violation) indicated in Article 83(2) of Regulation 2016/679 (see Chapter 5 of Guidelines 04/2022). These circumstances, which may have an aggravating or mitigating effect on the assessment of the violation, relate – as assumed by Guidelines 04/2022 – to the subjective side of the violation, that is to the entity itself that committed the violation and to its behavior before the violation, during its occurrence, and after it occurred. A detailed assessment and justification of the impact of each of

these criteria on the assessment of the violation have been presented above. The President of the UODO recognized that a mitigating circumstance...

In this case, the actions taken by the Company to minimize the damage suffered by the data subjects (Article 83(2)(c) of Regulation 2016/679) are considered. The remaining criteria (from Article 83(2)(d), (e), (f), (h), (i), (j), (k) of Regulation 2016/679) – as indicated above – did not have any mitigating or aggravating effect on the assessment of the violation and consequently on the imposition of the fine. Due to the presence of one mitigating circumstance in this case, it is therefore reasonable to further reduce the amount of the fine determined taking into account the Company's turnover (point 3 above); in the opinion of the President of the UODO, the appropriate reduction of this criterion's impact on the assessment of the violation is by 10% – to the amount of 2,025,000 EUR (equivalent to 9,549,900 PLN).

The President of the UODO stated that the amount of the administrative fine determined in the manner presented above does not exceed – in accordance with Article 83(3) of Regulation 2016/679 – the legally defined maximum amount of the fine provided for the most serious violation (see Chapter 6 of Guidelines 04/2022). As indicated above, the most serious violation in this case is the violation of Article 5(1)(f) and Article 5(2) of Regulation 2016/679, which is subject to an administrative fine of up to 20,000,000 EUR, or in the case of an enterprise - up to 4% of its total annual worldwide turnover from the previous financial year, with the higher amount being applicable. The President of the UODO determined that the "dynamic maximum amount" for this violation and for this violator expressed as a percentage (4%) of its turnover would amount to 8,833,367 EUR, therefore in this case, the "static maximum amount" of 20,000,000 EUR should be applied as the higher amount for the examined violation. The aforementioned amount of 2,025,000 EUR obviously does not exceed the amount of 20,000,000 EUR.

Despite the fact that the amount of the fine determined according to the above principles does not exceed the legally defined maximum, the President of the UODO considered that it requires additional adjustment due to the principle of proportionality mentioned in Article 83(1) of Regulation 2016/679 as one of the three directives for imposing a fine (see Chapter 7 of Guidelines 04/2022). Undoubtedly, a fine of 2,025,000 EUR would be an effective fine (due to its severity, it would achieve its repressive goal, which is to punish unlawful behavior) and deterrent (allowing effectively to discourage both the Company and other controllers from committing violations of the provisions of Regulation 2016/679 in the future). However, such a fine would be – in the opinion of the President of the UODO – disproportionate due to its excessive severity. The principle of proportionality requires, among other things, that the measures adopted by the supervisory authority do not go beyond what is appropriate and necessary to achieve legitimate objectives (see points 137 and 139 of Guidelines 04/2022). In other words: "A sanction is proportional if it does not exceed the threshold of severity determined by taking into account the circumstances of the specific case" (P. Litwiński (ed.), Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016 [...]; Commentary on Article 83 [in:] P. Litwiński (ed.) General Data Protection Regulation. Data Protection Act. Selected sectoral provisions. Commentary). Therefore, taking into account the proportionality of the fine, the President of the UODO further reduced the amount of the fine – to 40% of the amount obtained after considering the aggravating and mitigating circumstances (see point 4 above), that is to the amount of 810,000 EUR (equivalent to 3,819,960 PLN). In his opinion, such determination of the final amount of the imposed fine will not affect its effectiveness and deterrent nature. This amount constitutes a threshold above which any further increase in the amount of the fine would not be associated with an increase in its effectiveness and deterrent nature. On the other hand, a greater reduction in the amount of the fine could occur at the expense of its effectiveness and deterrent nature, as well as the consistent application and enforcement of Regulation 2016/679 and the principle of equal treatment of entities in the EU and EEA internal market.

According to the provisions of Article 103 of the Act of May 10, 2018 on the Protection of Personal Data (Journal of Laws of 2019, item 1781), the equivalent expressed in euros of the amounts referred to in Article 83 of Regulation 2016/679 is calculated in zlotys according to the average euro exchange



rate announced by the National Bank of Poland in the exchange rate table on January 28 of each year, and in the event that in a given year the National Bank of Poland does not announce the average euro exchange rate on January 28 – according to the average euro exchange rate announced in the nearest exchange rate table of the National Bank of Poland after that date.

Taking the above into account, the President of the Personal Data Protection Office, based on Article 83(4)(a) and Article 83(5)(a) in connection with Article 83(3) of Regulation 2016/679 and in connection with Article 103 of the Act of May 10, 2018 on the Protection of Personal Data, for the violation described in the operative part of this decision, imposed on Morele.net – applying the average euro exchange rate from January 30, 2023 (1 EUR = 4.7160 PLN) – an administrative fine in the amount of 3,819,960 PLN (in words: three million eight hundred nineteen thousand nine hundred sixty PLN), which constitutes the equivalent of 810,000 EUR.

II. At the same time, due to the finding of the Supreme Administrative Court that the authority made an incorrect and premature assessment that the Company did not document the deletion of data from installment applications, while according to the NSA, during the proceedings, the Company convincingly explained that the deletion of databases was documented in the IT system logs, it is stated...

**\*\*Decision\*\***

It should be noted that at the current stage of the proceedings, the explanations provided by the Company should be acknowledged in this regard. Moreover, the collection of personal data pertained to a period prior to the commencement of the application of Regulation 2016/679. Currently, judicial rulings narrow the possibility of assessing factual states prior to the application of this legal act through the lens of its provisions[10].

Considering the above, in the opinion of the President of the Personal Data Protection Office, in this regard of the matter at hand, it cannot be attributed to the Company a violation of the provisions of Regulation 2016/679, and therefore it is not justified for the President of the Personal Data Protection Office to exercise any corrective power referred to in Article 58(2) of Regulation 2016/679.

In this situation, the present proceedings are subject to dismissal based on Article 105 § 1 of the Administrative Procedure Code (k.p.a.), due to its lack of subject matter. According to the aforementioned provision, when the proceedings have become devoid of subject matter in whole or in part for any reason, the public administration authority issues a decision to dismiss the proceedings accordingly in whole or in part. The wording of the cited regulation leaves no doubt that in the event of establishing the lack of subject matter of the proceedings, the authority conducting the proceedings is obliged to dismiss it. At the same time, it is indicated in the literature on the subject that the lack of subject matter of administrative proceedings, as stated in Article 105 § 1 of the k.p.a., means that one of the elements of the material legal relationship is missing, and therefore it is not possible to issue a decision resolving the matter on its merits (B. Adamiak, J. Borkowski "Administrative Procedure Code. Commentary" 7th edition, C.H. Beck Publishing House, Warsaw 2005, p. 485). The same position was taken by the Provincial Administrative Court in Krakow in its judgment of February 27, 2008 (III SA/Kr 762/2007): "The proceedings become devoid of subject matter when one of the elements of the material legal relationship is missing, which means that the matter cannot be resolved on its merits."

The establishment by the public authority of the existence of the premise referred to in Article 105 § 1 of the k.p.a. obliges it to dismiss the proceedings, as there are no grounds for resolving the matter on its merits, and further conduct of the proceedings in such a case would indicate its defectiveness, which has a significant impact on the outcome of the case.

III. Referring to the request contained in the Company's letter of December 21, 2023, for the exclusion from participation in the proceedings of the employees who prepared the document "Analysis of the technical and organizational measures applied by Morele.net Sp. z o.o. based in Krakow that affect the occurrence of a violation of personal data protection...", due to justified concerns regarding the impartiality of the authors of the Analysis as employees of the Personal Data Protection Office, it should be indicated that this request is devoid of subject matter.

As the basis for the aforementioned request, the Company cited Article 24 § 3 of the k.p.a., according to which the direct supervisor of the employee is obliged, at the employee's request or at the request of a party or ex officio, to exclude them from participation in the proceedings if the existence of circumstances not mentioned in § 1 is substantiated, which may raise doubts about the impartiality of the employee.

At the outset, it should be noted that the employees of the Personal Data Protection Office who prepared the Analysis in execution of the judgment of the Supreme Administrative Court of February 9, 2023, case no. III OSK 3945/21, were selected due to their qualifications and experience in the area of information security issues, which, combined with their lack of involvement in previous actions conducted against the Company, also ensures their impartiality.

From the argumentation presented by the Company, it can be inferred that none of the employees of the Personal Data Protection Office would be sufficiently impartial, and for this reason, the Company's request is unfounded. The allegation of lack of impartiality directed essentially at all employees of the Personal Data Protection Office excludes the possibility of utilizing the institution of employee exclusion specified in Article 24 § 3 of the k.p.a.

In this factual and legal state, the President of the Personal Data Protection Office decided as stated in the operative part.

The decision is final. Based on Article 7 § 2 of the Act of May 10, 2018, on the protection of personal data (Journal of Laws of 2019, item 1781) in conjunction with Article 13 § 2, Article 53 § 1, and Article 54 of the Act of August 30, 2002, on proceedings before administrative courts (Journal of Laws of 2023, item 1634, as amended), a party dissatisfied with this decision has the right to file a complaint with the Provincial Administrative Court in Warsaw within 30 days from the date of delivery to the party. The complaint is submitted through the President of the Personal Data Protection Office (address: Personal Data Protection Office, ul. Stawki 2, 00-193 Warsaw). A court fee must be paid for the complaint, in accordance with Article 231 in conjunction with Article 233 of the Act of August 30, 2002, on proceedings before administrative courts (Journal of Laws of 2023, item 1634, as amended). The party has the right to apply for exemption from court costs or for legal aid.

According to Article 105 § 1 of the Act of May 10, 2018, on the protection of personal data (Journal of Laws of 2019, item 1781), the administrative fine must be paid within 14 days from the expiration of the deadline for filing a complaint with the Provincial Administrative Court, or from the day the ruling of the administrative court becomes final, to the bank account of the Personal Data Protection Office at NBP O/O Warsaw no. 28 1010 1010 0028 8622 3100 0000. Furthermore, according to Article 105 § 2 of the aforementioned Act, the President of the Personal Data Protection Office may, for justified reasons... Application of the penalized entity to postpone the deadline for payment of the administrative monetary penalty or to spread it over installments. In the case of postponement of the deadline for payment of the administrative monetary penalty or spreading it over installments, the President of the Personal Data Protection Office calculates interest on the unpaid amount at an annual rate, applying a reduced late payment interest rate, announced based on Article 56d of the Act of August 29, 1997 - Tax Ordinance (Journal of Laws of 2023, item 2383), from the day following the day of submission of the application.

According to Article 74 of the Personal Data Protection Act, the filing of a complaint by a party to the administrative court suspends the execution of the decision regarding the administrative monetary penalty.

[1] [https://owasp.org/www-pdf-archive/OWASP\\_Top\\_10-2017\\_%28en%29.pdf.pdf](https://owasp.org/www-pdf-archive/OWASP_Top_10-2017_%28en%29.pdf.pdf) [accessed 26.09.2023]

[2] <https://pages.nist.gov/800-63-3/sp800-63b.html> [accessed 26.09.2023]

[3] <https://www.enisa.europa.eu/publications/guidelines-for-smes-on-the-security-of-personal-data-processing> [accessed 26.09.2023]

[4] <https://www.isaca.org/resources/news-and-trends/isaca-now-blog/2018/the-multiple-options-for-mul>

ti-factor-authentication [accessed 26.09.2023]

[5] <https://www.microsoft.com/en-us/research/publication/password-guidance/> [accessed 26.09.2023]

[6] <https://www.microsoft.com/en-us/security/blog/2019/08/20/one-simple-action-you-can-take-to-prevent-99-9-percent-of-account-attacks/> [accessed 26.09.2023]

[7] See the Guide of the Banking Technology Forum at the Polish Bank Association "Identification and Authentication in Electronic Services", Warsaw 2013

[8] <https://uodo.gov.pl/pl/537/2902>

[9] Guidelines in English at: [https://edpb.europa.eu/our-work-tools/our-documents/guidelines/guideline-s-042022-calculation-administrative-fines-under\\_pl](https://edpb.europa.eu/our-work-tools/our-documents/guidelines/guideline-s-042022-calculation-administrative-fines-under_pl)

[10] Judgment of the WSA dated October 21, 2021, case file II SA/Wa 272/21.

Print article

Metadata

Entity providing the information:

Department of Control and Violations

Information created by:

Jan Nowak

2024-01-17

Information entered by:

Maria Jęda

2024-02-09 12:30:02

Last modified by:

Karolina Jastalska

2024-02-14 12:55:24